

Northwind Information Technology & Data Governance Policy

Enterprise Security Standards, Access Control, Data Privacy & RAG Integration Governance

1. Purpose, Scope & Governance Architecture

This policy defines the operational rules, security controls, data classification governance, and acceptable use guidelines for Northwind Traders' Information Technology (IT) infrastructure and enterprise data assets. It applies to all full-time employees, contractors, third-party logistics vendors, and automated software agents (including AI and Retrieval-Augmented Generation systems) accessing Northwind databases, networks, and communication tools.

Mandatory Security Directive: All corporate devices and services must enforce Multi-Factor Authentication (MFA) and least-privilege role-based access controls (RBAC). Unauthenticated access to relational database stores or RAG vector indexes is strictly prohibited.

2. Enterprise IT Security Standards

2.1 User Access Control & Identity Management

Account Management & Password Governance

User credentials must be managed centrally via Microsoft Active Directory / Entra ID. Access rights are granted based on the principle of Least Privilege and Role-Based Access Control (RBAC).

- **Password Complexity:** Minimum 14 characters incorporating uppercase, lowercase, numerical, and special characters. Passwords expire every 90 days.
- **Multi-Factor Authentication (MFA):** Hardware key or authenticator app MFA is required for all local, VPN, and cloud application logins. SMS-based MFA is disallowed.
- **Session Termination:** Inactive terminal sessions automatically lock after 15 minutes of non-activity.

RAG Query Mapping: Answers queries like "What are Northwind password requirements?", "How often do passwords expire?", or "Is MFA mandatory for remote workers?".

2.2 Database & Data Classification Policy

Data Tiering & Confidentiality Levels

Northwind classifies all enterprise data into four distinct security tiers to ensure compliance with international data privacy laws (GDPR, CCPA):

- **Public (Tier 1):** Product catalog descriptions, publicly listed retail prices, published marketing material.
- **Internal (Tier 2):** Standard operational guidelines, general employee directory, non-sensitive inventory levels.
- **Confidential (Tier 3):** Customer order history, wholesale discount schedules, supplier contracts, regional revenue reports.
- **Restricted (Tier 4):** Personally Identifiable Information (PII) like customer credit cards, employee tax records, corporate financial ledgers, and API keys.

RAG Query Mapping: Answers queries like "What are Northwind's data sensitivity tiers?", "How is customer PII handled?", or "Can RAG models access Tier 4 restricted data?".

2.3 AI & RAG Agent Governance Policy

Retrieval-Augmented Generation (RAG) Security Protocols

Large Language Models (LLMs) and RAG agents querying Northwind's database or document stores must adhere to strict security constraints:

- **PII Redaction:** Vector index embeddings must automatically redact or hash customer credit card details, passwords, and employee tax identifiers prior to vectorization.
- **Context Window Sanitization:** Prompt templates must include explicit system guardrails to prevent SQL injection, system prompt leakage, or context manipulation.
- **Audit Logging:** All automated LLM tool calls and database queries generated by AI agents must be logged to a central immutable SIEM (Security Information and Event Management) audit trail.

RAG Query Mapping: Maps to queries like "What are the rules for AI agents in Northwind?", "How does RAG prevent PII leaks?", or "Where are AI query logs stored?".

2.4 Acceptable Use & Device Management

Northwind-issued hardware (laptops, mobile devices, barcode scanners) must remain managed under the Enterprise Mobile Device Management (MDM) portal. Key directives include:

- **BitLocker Encryption:** Full-disk encryption must be active on 100% of portable workstations.
- **Software Installation:** Unapproved executable files (.exe, .sh) or browser extensions are blocked by default via Application Whitelisting.
- **Remote Work:** Connections to internal network assets from public Wi-Fi networks must be routed through the enterprise encrypted VPN tunnel.

2.5 Incident Response & Backup Recovery SLAs

In the event of a cybersecurity breach, data loss, or system outage, the IT Infrastructure Team operates under strict Service Level Agreements (SLAs):

- **Critical Outage (Tier 1 System Down):** RTO (Recovery Time Objective) = 2 Hours; RPO (Recovery Point Objective) = 15 Minutes.
- **Database Backup Schedule:** Full database backups nightly at 00:00 UTC; differential backups every 4 hours; transaction log backups every 15 minutes.
- **Security Incident Notification:** Any confirmed or suspected data breach involving Tier 3 or Tier 4 data must be reported to the Chief Information Security Officer (CISO) within 1 hour.

3. Summary Matrix of IT Policy Rules & RAG Retrieval Patterns

Policy Domain	Primary Regulation / Standard	Enforcement Mechanism	RAG Natural Language Target Queries
Access Security	14+ Char Password, MFA, Active Directory	Entra ID RBAC & Local Lockouts	"How do I reset my password?", "MFA policy details"
Data Privacy	GDPR / CCPA / 4-Tier Data Classification	Automated PII Masking & Column Encryption	"Data classification tiers", "Handling customer PII"
AI / RAG Controls	Least Privilege Embeddings & SIEM Logging	Prompt Guardrails & Vector Sanitization	"AI security rules", "Can RAG access payroll data?"
Disaster Recovery	RTO = 2 Hours, RPO = 15 Mins	Automated Transaction Log Backups	"What is the database recovery time objective?", "Backup schedule"
Device Security	Full-Disk BitLocker, MDM Enforcement	App Whitelisting & Enforced VPN	"Connecting to corporate VPN", "Laptop encryption policy"